

گزارش امنیت و پرفورمنس – اپلیکیشن Ritme

لودتست · تحلیل گلوگاه‌ها · پن‌تست · رفع آسیب‌پذیری‌ها

تاریخ: ۱۴۰۵/۰۶/۰۷ (۲۰۲۶-۰۸-۲۹) · محیط تست: بک‌اند لوکال (Laravel + SQLite) روی 8010: با دیتای واقعی

۸ مورد رفع‌شده

۳۳۳ تست بک‌اند

۳۳,۶۷۲ رکورد سیکل

۲۶ کاربر

این گزارش دو لایه کار را پوشش می‌دهد: (۱) تست زنده‌ی runtime روی سرور لوکال با دیتای واقعی، و (۲) آدیت کد کامل (۱۷ کنترلر ۲۰ API، کنترلر ادمین، روت‌ها، سیدرها، Docker/nginx). همه‌ی موارد بحرانی به‌صورت زنده تأیید و سپس رفع شدند. هر رفع با اجرای مجدد تست‌ها و بررسی زنده اعتبارسنجی شد.

۱. خلاصه‌ی مدیریتی

اپلیکیشن زیر بار **پایدار** است (هیچ crash/خطا تا concurrency=۱۰). کنترل‌های امنیتی پایه قوی بودند: IDOR، mass-assignment، SQLi، path-traversal و آپلود فایل همگی امن. اما چند آسیب‌پذیری **بحرانی** در سطح deploy/config کشف شد که مهم‌ترینشان افشای دیتای سلامتی کاربران بدون احراز هویت بود. یک گلوگاه پرفورمنس جدی (N+1) هم شناسایی و رفع شد.

333

تست سبز بعد از تغییرات

16x

کاهش کوئری cycle/month

3

بحرانی (Critical)

8

مورد رفع‌شده و تأییدشده

۲. لودتست و پرفورمنس

پروفاایل تعداد کوئری هر اندپوینت از طریق HTTP kernel با query-log گرفته شد. تست بار با ab (Apache Bench). نکته: artisan serve تک‌ورکر است، پس RPS سقف هر ورکر است؛ اما latency، تعداد کوئری و ترتیب گلوگاه‌ها معتبر و مستقل از تعداد ورکر است.

گلوگاه‌های شناسایی‌شده (قبل از رفع)

مشکل	اندپوینت	کوئری	حجم پاسخ	p50 زیر بار c=10
N+1: تاریخچه‌ی سیکل روی هر ۳۱ روز دوباره کوئری می‌شد	cycle/month	64	91 KB	2598ms
همان ۱۷، N+1 تکرار	home	39	9.5 KB	882ms

recalculate (job)	743	–	async	جاب سنگین؛ در prod روی queue worker (redis) اجرا می‌شود، نه request-path
بقیه اندپوینت‌ها	0-4	کوچک	خوب	سالم

ریشه‌ی گلوگاه

HealthDataEngine::getCycleHistories() روی هر بار صدا زدن calculateForDate() یک SELECT * FROM cycle_histories تازه می‌زد بدون memoization. کنترلر month() این را در یک حلقه‌ی ۳۱ روزه صدا می‌زد → ۳۱ کوئری یکسان + ۳۱ کوئری لاگ روزانه.

نتیجه‌ی رفع (اندازه‌گیری‌شده)

معیار	قبل	بعد	بهبود
کوئری‌های cycle/month	64	4	۱۶× کمتر
کوئری‌های home	39	32	۷-
p50 زیر بار c=10 (cycle/month)	2598ms	603ms	۴.۳× سریع‌تر
Throughput (cycle/month , c=1)	8.5 rps	15.5 rps	۱.۸×

✓ پاسخ خروجی **byte-identical** ماند (بدون تغییر رفتار). راهکار: memoize کردن تاریخچه + preload لاگ‌های کل ماه در یک کوئری با whereBetween .

۳. پنتست – آسیب‌پذیری‌های رفع‌شده

C1 – روت‌های /test-* بدون احراز هویت CRITICAL

۵۳ روت روی گروه web بدون auth و بدون گیت محیط. تست زنده: GET /test-page/profile و /test-pregnancy/symptoms و /test-pregnancy/alerts همگی ۲۰۰ بدون توکن. همه روی یک شماره‌ی ثابت (09123456789 – یک موبایل معتبر ایرانی) کار می‌کنند و کل دیتای سیکل/بارداری/علائم را می‌خوانند و تغییر می‌دهند. nginx پروداکشن فقط /admin را می‌بست.
✓ رفع: گیت همه‌ی روت‌ها با app()->environment('local') . تأیید: در ۰ → prod روت، در local دست‌نخورده.

C2 – ریست پسورد سوپرادمین به admin1234 در هر deploy CRITICAL

AdminSeeder از updateOrCreate استفاده می‌کرد → پسورد/نقش را در هر ری‌استارت کانتینر overwrite می‌کرد؛ و docker-compose.yml مقدار پیش‌فرض admin1234 را تزریق می‌کرد. نتیجه: لاگین سوپرادمین با کردنشال پیش‌فرض روی adpanell.rtime.app.
✓ رفع: تبدیل به firstOrCreate (ادمین موجود دیگر overwrite نمی‌شود) + حذف fallback و fail-loud + الزامی‌کردن ADMIN_SEED_PASSWORD در compose. تأیید: reseed بدون تغییر؛ compose بدون متغیر ارور می‌دهد.

C3 – brute-force C3 کد OTP چهاررقمی CRITICAL

سقف تلاش یک TOCTOU race بود (خواندن مدل + UPDATE جدا، بدون lock) → ریکوئست‌های موازی همه با attempts=0 رد می‌شدند. علاوه بر آن هیچ throttle سراسری روی /api/* نبود (تأیید زنده: ۳۰ ریکوئست، ۰ تا ۴۲۹).
✓ رفع: claim اتمیک با where('attempts', '<', max)->increment() + مقایسه‌ی constant-time با hash_equals + throttle. تأیید زنده: قفل دقیقاً در تلاش ۶ام.

H1 – SMS-bombing و enumeration کاربران HIGH

پاسخ send-otp فیلد new_user را برمی‌گرداند → هرکس می‌توانست بفهمد کدام شماره‌ها کاربر اپ پریود/بارداری هستند (نقض حریم خصوصی). بدون محدودیت IP هم SMS-bombing ممکن بود.
✓ رفع: حذف new_user از پاسخ (کلاینت آن را از verify-otp می‌گیرد) + throttle:5,1 روی IP. تأیید زنده: ریکوئست ۶ام → ۴۲۹.

H2 – لاگین ادمین بدون rate-limit HIGH

گروه web در ۱۲ Laravel هیچ throttle ندارد → حدس نامحدود پسورد روی پنل ادمین (تشدید C2).
✓ رفع: throttle:5,1 روی روت لاگین ادمین.

H3 — APP_DEBUG true احتمالی در پروداکشن HIGH

docker-compose.yml پیش فرض APP_ENV: local / APP_DEBUG: true داشت و در overlay پروداکشن override نشده بود → اگر .env سرور ست نمی کرد، هر خطای ۵۰۰ استک تریس با کلیدهای SMS/DB را نشان می داد. ✓ رفع: hardcode کردن APP_ENV: production و APP_DEBUG: "false" برای backend و queue در overlay پروداکشن. تأیید: خروجی compose config.

M1 — Swagger عمومی → پشت رمز رفت MEDIUM

UI و اسپیک کامل OpenAPI بدون احراز هویت در دسترس بودند؛ اسپیک به صورت فایل استاتیک در public/docs/ سرو می شد و کاملاً می دلور را دور می زد. همچنین generate_always=true یعنی هر ریکوئست اسپیک را بازتولید می کرد (DoS). ✓ رفع: می دلور SwaggerBasicAuth (HTTP Basic با SWAGGER_USER / SWAGGER_PASSWORD) روی همه ی روت ها؛ انتقال اسپیک به storage/ (بیرون webroot)؛ حذف public/docs/؛ تولید یک بار موقع بوت. تأیید: زنده: بدون رمز ۴۰۱، با رمز ۲۰۰؛ در local باز. -fail prod در closed.

۴. مواردی که بررسی و امن تأیید شدند

حوزه	وضعیت	توضیح
IDOR / کنترل دسترسی	امن	همه‌ی روت‌های <code>{id}/{date}/{period}</code> با <code>user_id</code> scope شده‌اند؛ تست زنده: ۴۰۴/۴۲۲ روی منابع کاربر دیگر
Mass assignment	امن	FormRequest پروفایل فیلدهای ناشناخته را صریحاً رد می‌کند (whitelist سخت)
SQL Injection	امن	پارامتری (Eloquent)؛ تزریق تاریخ رد شد؛ جدول users سالم
Path traversal	امن	<code>realpath</code> + <code>allowlist</code> پسوند + <code>basename</code>
آپلود فایل	امن	هش‌نیم + بررسی <code>mime</code> + <code>re-encode</code> با حذف EXIF
XSS مقالات	امن	HtmlSanitizer با <code>allowlist</code> تگ/ <code>attribute/scheme</code>
بک‌دور OTP	امن	هیچ <code>test-mode</code> یا <code>bypass</code> در کد/کانفیگ/ <code>env</code>
افشای secret	امن	هیچ <code>.env</code> / کلیدی در <code>git</code> ردیابی نشده؛ کد OTP در لاگ نمی‌رود
CORS	امن	محدود به <code>web.ritime.app + localhost</code> ، credentials خاموش

۵. موارد باقی‌مانده (پیشنهاد برای ادامه)

- M2 – XSS (MED) ذخیره‌شده در بنر `link_url` نوع `internal` (پیلود: `javascript:`)
- M3 – bind (MED) پورت بک‌اند روی همه اینترفیس‌ها در فایل `base` + `trustProxies('*')`
- M4 (MED) – کوکی سشن ادمین بدون فلگ `Secure` و بدون HSTS
- M5 (MED) – توکن Passport یک‌ساله بدون `scope` در `localStorage`

۶. فایل‌های تغییرکرده در این سشن

فایل	تغییر	مربوط به
<code>app/Http/Middleware/SwaggerBasicAuth.php</code>	جدید (57+)	M1
<code>routes/web.php</code>	+64 -55	C1
<code>database/seeder/AdminSeeder.php</code>	+17 -2	C2
<code>app/Http/Controllers/Api/V1/OtpAuthController.php</code>	+56 -50	C3, H1
<code>routes/api.php</code>	+9 -3	C3, H1
<code>routes/admin.php</code>	+4 -1	H2
<code>docker-compose.yml</code> / <code>.prod.yml</code>	+26 -3	C2, H3, M1

پرفورمنس N+1	+48 -4	app/Services/HealthEngine/HealthDataEngine.php
پرفورمنس N+1	+3 -0	app/Http/Controllers/Api/V1/CycleCalculationController.php
M1	+44 -7	bootstrap/app.php · config/l5-swagger.php · entrypoint.sh · blade · .env.example

اقدام لازم موقع **deploy**: متغیر `SWAGGER_PASSWORD=<رمز قوی>` و `ADMIN_SEED_PASSWORD=<رمز قوی>` را در `.env` سرور تنظیم کنید. اگر پسورد ادمین لایو قبلاً `admin1234` بوده، فوراً چرخش دهید.

اعتبارسنجی نهایی: هر ۳۳۳ تست بک‌اند سبز · Pint (استایل) روی همه‌ی فایل‌های تغییرکرده تمیز · `verify-otp` با کد درست همچنان توکن معتبر می‌دهد · هیچ تغییری هنوز `commit` نشده (در `working tree` برای مرور).